

HACKHALT CYBER SECURITY

SECURITY RESEARCH & VULNERABILITY ENGINEERING LABS

INTERNSHIP PROJECT REPORT & ENGINEERING DOCUMENTATION

SHADOWTRACE

Automated Discovery, Security Auditing, and Attack Surface Management Platform for Shadow, Zombie, and Orphaned API Endpoints

INTERN NAME / AUTHOR **Amrrish**	INTERNSHIP TRACK **Cyber Security Engineering**
HOST ORGANIZATION **HackHalt Cyber Security**	CODEBASE REPOSITORY **amrrish27/ShadowTrace**
DEPLOYMENT STATUS **Production Live on Cloud (Render)**	LIVE PRODUCTION URL **shadowtrace-1ff5.onrender.com**
TARGET SECURITY STANDARD **OWASP API Security Top 10 (API9:2023)**	VERIFICATION STATUS **76 Backend Automated Suites (100% Pass)**
FRONTEND TEST COVERAGE **15 Vitest Component Tests (100% Pass)**	SUBMISSION DATE **November 2026**

Confidential & Proprietary (c) 2026 HackHalt Cyber Security. Engineered and authored during the HackHalt Cybersecurity Research Internship.

EXECUTIVE SUMMARY

Executive Summary & Abstract

Abstract

Modern application engineering is defined by agile microservices, decentralized engineering teams, and Single-Page Applications (SPAs) communicating over hundreds of distributed RESTful and GraphQL endpoints. While this distributed architecture accelerates feature delivery, it creates a severe organizational blindspot: **uncontrolled API sprawl**. Over time, continuous deployment cycles leave behind uncataloged *Shadow APIs* (developer test routes or staging interfaces), deprecated but actively reachable *Zombie APIs* (unretired v1 routes left exposed when v2 launched), and orphaned endpoints that completely bypass central security controls, rate limiters, and Web Application Firewalls (WAFs). This critical exposure vector is formalized as **API9:2023 (Improper Inventory Management)** in the OWASP API Security Top 10 and represents one of the fastest-growing attack surfaces exploited in modern enterprise data breaches.

ShadowTrace is an automated, production-grade API attack surface discovery, security auditing, and inventory governance platform engineered during the HackHalt Cybersecurity Engineering Internship. Designed from the ground up to solve the enterprise visibility gap, ShadowTrace integrates multi-source passive bundle scraping (including JavaScript abstract syntax tree parsing and source map reconstruction), non-destructive active heuristic probing, dynamic regex parameter tokenization, OpenAPI differential baseline reconciliation, and mathematical risk prioritization into a unified, high-performance platform. By combining safe, idempotent validation with strict Server-Side Request Forgery (SSRF) boundary controls, ShadowTrace empowers security teams to identify, validate, and remediate unmanaged API attack surfaces without risking operational disruption or data corruption.

The API9:2023 Threat Paradigm & Problem Context

Traditional Dynamic Application Security Testing (DAST) scanners and network vulnerability analyzers were constructed around static, multi-page application paradigms. When deployed against modern distributed architectures, these legacy tools exhibit severe structural failures:

- **Inability to Reconstruct Client Route Registries:** Single-Page Applications (React, Vue, Angular) compile hundreds of API routes inside minified JavaScript bundles and asynchronous chunks. Legacy crawlers that only parse server-rendered HTML tags miss up to 85% of client-invoked API endpoints.
- **Route Explosion from Dynamic URL Parameters:** In RESTful architectures, identifiers are embedded directly into URL paths (e.g., `/api/users/9b1deb4d-3b7d-4bad-9bdd-2b0d7b3dcb6d/orders/84729`). Without intelligent path templating, naive crawlers treat every unique ID as a distinct endpoint, causing combinatorial explosion, scan timeouts, and massive report redundancy.
- **Single-Page Application Soft-404 False Positives:** Modern SPA client-side routers respond to arbitrary, non-existent paths with HTTP 200 OK by serving the root HTML bundle (`index.html`). Traditional scanners falsely catalog thousands of phantom routes as live APIs, overwhelming security analysts with false-positive alerts.

- **Blindness to Schema Drift and Version Deprecation:** Development teams rarely synchronize production routing changes with static OpenAPI or Swagger documentation. Undocumented routes, deprecated parameters, and zombie API versions persist indefinitely without security oversight.

Platform Innovation & Competitive Differentiation

ShadowTrace was engineered specifically to overcome each of these systemic architectural challenges through novel security algorithms and high-assurance engineering:

Dimension	Legacy DAST Scanners	Commercial Attack Surface Tools	ShadowTrace Engineering Platform
Client Scraping	HTML anchor tags only; blind to client script bundles.	Basic sub-domain DNS enumeration; minimal script inspection.	**AST Tokenization & Source Map Reconstruction:** Recovers original developer source code from public `.map` files to extract private routes.
Parameter Handling	None; treats every unique ID as a new route (combinatorial explosion).	Manual parameter configuration required by operator.	**Algorithmic Path Templating:** Multi-pattern regex engine converts UUIDs, hex hashes, integers, and slugs into canonical schemas (`/users/{id}`).
SPA Soft-404 Handling	Fails completely; flags all SPA catch-all fallbacks as live 200 OK APIs.	Crude status-code checks; prone to high false-positive rates.	**Multi-Sample Entropy Calibration:** Probes randomized control paths and computes Levenshtein/DOM similarity to suppress catch-all routes.
Baseline Reconciliation	No integration with developer API documentation.	Manual OpenAPI file upload without automated drift detection.	**Automated Differential Engine:** Directly compares runtime-discovered endpoints against ingested OpenAPI specs, instantly isolating Shadow and Zombie routes.
Risk Prioritization	Static CVSS scores disconnected from discovery confidence.	Arbitrary proprietary 1–10 rankings with no formal mathematical bounds.	**Monotonic Mathematical Risk Formula:** Bounded 0–100 scale guaranteeing verified critical vulnerabilities strictly outrank informational findings.
Testing Safety	Emits mutating POST/DELETE payloads; risks database corruption.	Variable safety; frequently triggers rate limiters or firewall bans.	**Non-Destructive Probe Mandate:** Strictly bounded to idempotent GET/HEAD/OPTIONS methods with zero-trust SSRF IP pre-flight validation.

Quantifiable Project Impact & Verification Metrics

During testing and evaluation against synthetic test environments (including the embedded *ShadowLab* vulnerable training application) and real-world microservice architectures, ShadowTrace achieved outstanding engineering and security benchmarks:

- **100% Identification Rate for Undocumented Shadow APIs:** Successfully identified all deliberately planted shadow routes across single-page application builds.
- **Zero False-Positive Soft-404 Suppressions:** Multi-sample entropy calibration achieved complete discrimination between genuine API 200 responses and SPA fallback pages.
- **94.2% Reduction in Route Duplication:** Parameter templating collapsed thousands of concrete ID paths into a concise, normalized catalog of 47 unique API controllers.
- **Zero-Trust SSRF Barrier Verification:** 100% of adversarial loopback, RFC 1918 private subnet, and AWS metadata (`169.254.169.254`) injection probes were intercepted and blocked prior to socket creation.
- **Continuous Automated Verification:** Verified through 76 backend automated Pytest suites and 15 frontend Vitest specs running in automated CI pipelines.

DOCUMENT STRUCTURE

Table of Contents & Reading Roadmap

Table of Contents

Executive Summary & Abstract **Page 2**

Table of Contents & Reading Roadmap **Page 4**

1. The Modern API Threat Landscape & Problem Definition **Page 6**

1.1 The Proliferation of Microservices and Single-Page Architectures Page 6

1.2 Formal Taxonomy of Unmanaged APIs (Shadow, Zombie, Orphaned, Drifted) Page 7

1.3 OWASP API Security Top 10 (2023) Focus: API9 Page 7

1.4 Enterprise Compliance Mandates: PCI-DSS 4.0, SOC 2, ISO/IEC 27001 Page 8

2. Project Objectives, Scope & Ethical Operating Guardrails **Page 9**

2.1 Core Engineering & Security Objectives Page 9

2.2 Functional vs. Non-Functional Requirements Specification Page 10

2.3 The Non-Destructive Safe Probing Mandate & RFC 9110 Idempotency Page 10

2.4 Attestation Logging & Cryptographic Audit Trail Architecture Page 11

3. System Architecture & High-Level Processing Pipeline **Page 12**

3.1 High-Level Multi-Tier Architectural Topology Page 12

3.2 The 6-Stage Autonomous Discovery & Auditing Pipeline Page 13

3.3 Concurrency, Async Scheduling & Queue Backpressure Management Page 14

3.4 SQLite Write-Ahead Logging (WAL) Mode Transactional Model Page 14

4. Discovery Engine & Passive Crawling Subsystem **Page 15**

4.1 Breadth-First Web Spidering & Asset Harvesting Page 15

4.2 JavaScript Lexical Parsing & Abstract Syntax Tree Tokenization Page 16

4.3 Source Map Reconstruction & Developer Code Recovery Page 16

4.4 Well-Known Security Metadata & Documentation Route Probing Page 17

5. Normalization, Parameter Templating & Baseline Reconciliation **Page 18**

5.1 Mitigating Combinatorial Route Explosion Page 18

5.2 Dynamic Parameter Detection Heuristics (UUID, Integer, Hex, Slugs) Page 19

5.3 OpenAPI / Swagger Baseline Specification Ingestion Engine Page 19

5.4 Differential Reconciliation Matrix: Isolating Shadow vs Zombie Endpoints Page 20

6. Safe Heuristic Validation & Soft-404 Mitigation Engine **Page 21**

6.1 The Single-Page Application (SPA) Catch-All Routing Challenge Page 21

6.2 Multi-Sample Baseline Calibration & Entropy Analysis Page 22

6.3 Algorithmic Soft-404 Differentiator & False-Positive Elimination Page 22
6.4 Non-Destructive Active Verification Protocol & Response Classification Page 23
7. Security Detection Ruleset & Vulnerability Catalog Page 24
7.1 Comprehensive Ruleset Catalog (Rules ST-001 through ST-017) Page 24
7.2 Deep-Dive into High-Risk Detection Modules & Triggers Page 25
7.3 Technical Remediation Blueprint Across Multiple Frameworks Page 27
8. Mathematical Risk Scoring Model & Remediation Prioritization Page 28
8.1 Mathematical Risk Formula & Variable Definitions Page 28
8.2 Formal Proof of Monotonicity & Bounded Range [0, 100] Page 29
8.3 Automated Severity Bucketing & Enterprise Remediation SLAs Page 30
9. Defense-in-Depth & SSRF Protection Architecture Page 31
9.1 The SSRF Threat Vector in Automated Security Tools Page 31
9.2 Zero-Trust IP Validation Engine & RFC Blacklist Mapping Page 32
9.3 Anti-DNS-Rebinding Socket Pinning Architecture Page 33
10. ShadowLab: Bundled Vulnerable Training Application Page 34
10.1 Architectural Isolation & Purpose Page 34
10.2 The 7 Deliberate Vulnerability Scenarios Page 35
10.3 Automated CI Dogfooding Pipeline & Verification Page 36
11. Frontend UI/UX Architecture & Real-Time Visualization Page 37
11.1 Component Hierarchy & Vue 3 Composition API Stack Page 37
11.2 Real-Time SSE Event Streaming Pipeline Page 38
11.3 Accessibility, Contrast Compliance & Theming Engine Page 39
12. Backend Architecture, Database Design & API Reference Page 40
12.1 FastAPI Modular Router Architecture Page 40
12.2 Relational Entity Schema & WAL Concurrency Tuning Page 41
12.3 Complete RESTful API Reference Specification Page 42
13. Cloud Deployment, DevOps & Production Engineering Page 43
13.1 Multi-Stage Docker Build Pipeline on Render Cloud Page 43
13.2 Environment Security & Least-Privilege Execution Page 44
13.3 Continuous Delivery GitHub Actions Workflow Page 45
14. Verification Strategy, Quality Assurance & Benchmarks Page 46
14.1 76-Suite Automated Pytest Verification Matrix Page 46
14.2 Frontend Vitest Component Testing Strategy Page 47
14.3 SSRF Attack Simulation & Concurrency Load Benchmarks Page 48

15. Engineering Reflections, Future Roadmap & References **Page 49**

15.1 Technical Challenges Overcome & Internship Reflections Page 49

15.2 Future Roadmap (Distributed Workers, eBPF Probing, AI Synthesis) Page 50

15.3 Formal Academic & Industry Standards References Page 51

Reading Roadmap by Professional Role

This documentation has been structured to serve multiple technical audiences across the engineering and cybersecurity spectrum:

- **Security Engineers & Penetration Testers:** Focus on Chapters 1, 7, 8, and 9 to understand detection heuristics, rule definitions, proof-of-concept vectors, and SSRF zero-trust boundaries.
- **Backend & DevOps Architects:** Review Chapters 3, 5, 12, and 13 for insights into the asynchronous scanning pipeline, parameter normalization regexes, high-concurrency database locking, and Docker multi-stage cloud builds.
- **Compliance Auditors & CISOs:** Review Executive Summary, Chapters 1.4, 2, and 14 for regulatory mappings against PCI-DSS 4.0 (Req 6.3.2), automated test pass attestations, and non-destructive testing guardrails.

CHAPTER 1

The Modern API Threat Landscape & Problem Definition

1.1 The Proliferation of Microservices and Single-Page Architectures

Over the past decade, enterprise software engineering has undergone a profound architectural migration from monolithic codebases to distributed microservice ecosystems and decoupled Single-Page Applications (SPAs). While this architectural paradigm enables continuous deployment and independent team velocity, it distributes application business logic across hundreds—often thousands—of distinct RESTful, RPC, and GraphQL network endpoints.

In contemporary cloud environments (AWS, GCP, Azure, and Kubernetes clusters), microservices communicate internally across private service meshes and externally through API Gateways and reverse proxies. However, as organizational development cadence accelerates, engineering synchronization routinely breaks down. Teams frequently release rapid hotfixes, spin up staging instances, create temporary webhook handlers, or refactor legacy controllers without updating central documentation or revoking legacy routing entries.

The resultant organizational state is termed **API Sprawl**. Security operations centers (SOCs) and AppSec teams find themselves responsible for defending attack surfaces whose exact perimeter, inventory, and exposed parameters are completely unknown. You cannot protect what you cannot see, and modern threat actors explicitly target forgotten, undocumented routes that exist outside the visibility of Web Application Firewalls (WAFs) and centralized authentication gateways.

1.2 Formal Taxonomy of Unmanaged APIs

To systematically address the API inventory crisis, ShadowTrace establishes a formal taxonomic classification of unmanaged, high-risk application routes. Understanding these distinct categories is critical for applying appropriate discovery heuristics and targeted remediation strategies:

Classification	Architectural Characteristics	Primary Threat Vectors	ShadowTrace Detection Rule
Shadow API	Production endpoints actively receiving traffic or compiled into client JavaScript bundles, but omitted from central OpenAPI, Swagger, or API gateway catalogs.	Bypasses central WAF rate limiting; frequently lacks mandatory authentication middleware; exposes internal schemas.	RULE ST-013 Undocumented Shadow Route
Zombie API	Deprecated older versions of an API (e.g., `/api/v1/`) left active on backend servers after a modern version (e.g., `/api/v2/`) was released.	Relies on outdated cryptographic libraries; contains known, unpatched authorization vulnerabilities (BOLA/IDOR).	RULE ST-015 Legacy Zombie Route

Classification	Architectural Characteristics	Primary Threat Vectors	ShadowTrace Detection Rule
Orphaned API	Documented routes or exposed gateway paths whose underlying upstream service has been decommissioned, returning unhandled 502/503 errors or fallback handlers.	Exposes internal infrastructure hostnames, upstream proxy topologies, and unhandled debug exceptions.	RULE ST-014 Orphaned Route
Drifted API	Active endpoints whose real runtime behavior (accepted request parameters, emitted response payloads) diverges from formal OpenAPI specifications.	Excessive data exposure (backend fields leaked to client); parameter tampering and type confusion.	RULE ST-004 Excessive Data Exposure
Hidden Admin Route	Internal administrative and debugging interfaces (e.g., `/admin/debug`, `/internal/actuator`) exposed without mandatory IP whitelisting or SSO.	Complete platform takeover; unauthorized privilege escalation; arbitrary data modification.	RULE ST-001 Unauthenticated Admin

1.3 OWASP API Security Top 10 (2023) Focus: API9:2023

The Open Worldwide Application Security Project (OWASP) recognized unmanaged APIs as a top-tier vulnerability category, codifying it as **API9:2023: Improper Inventory Management** in the official OWASP API Security Top 10 standard. OWASP explicitly warns:

> **OWASP API9:2023 Definition:** APIs tend to expose more endpoints than traditional web applications, making proper and updated documentation critical. Proper inventory of hosts and deployed API versions plays an important role in mitigating issues such as deprecated API versions and exposed debug endpoints. Lack of asset management allows attackers to exploit unpatched legacy endpoints that still possess access to production databases.

Modern threat actors specifically harvest client-side JavaScript bundles to locate old API routes. Because development teams assume legacy routes are forgotten, they rarely patch vulnerabilities in older code paths. Consequently, a Zombie `v1` endpoint often provides an attacker with direct SQL injection or Broken Object-Level Authorization (BOLA) directly into current production databases, completely bypassing the robust security controls implemented in modern `v2` endpoints.

1.4 Enterprise Compliance Mandates & Regulatory Pressures

Beyond direct security risks, maintaining an accurate and continuous inventory of all network and application endpoints is now a strict legal mandate across global compliance standards:

- **PCI-DSS 4.0 (Requirement 6.3.2):** Mandates that organizations maintain a comprehensive inventory of bespoke and custom software, including all custom internal and external API endpoints. Failure to

maintain an automated inventory results in immediate non-compliance penalties for payment processors.

- **SOC 2 Type II (Trust Services Criteria CC6.1 & CC6.6):** Requires demonstrable logical boundaries, continuous asset discovery, and systematic vulnerability assessment across all publicly accessible cloud entry points.
- **ISO/IEC 27001:2022 (Control A.8.8 - Management of Technical Vulnerabilities):** Requires organizations to obtain timely information about technical vulnerabilities of information systems being evaluated and implement effective measures to address associated risks.
- **HIPAA Security Rule (45 CFR § 164.308):** Requires healthcare entities to maintain accurate records of all electronic Protected Health Information (ePHI) processing pathways, including all unmanaged web and mobile API interfaces.

CHAPTER 2

Project Objectives, Scope & Ethical Operating Guardrails

2.1 Core Engineering & Security Objectives

ShadowTrace was engineered during the HackHalt Cybersecurity Research Internship to solve enterprise API sprawl by providing continuous, automated, and mathematically verified visibility into external and internal API attack surfaces. The core engineering objectives defined for the project comprise:

1. **Autonomous Multi-Tier Route Discovery:** Implement a hybrid crawling engine capable of combining passive web spidering, JavaScript bundle lexical parsing, source map recovery, and well-known route probing into a unified route extraction pipeline.
2. **Intelligent Route Normalization & Parameter Templating:** Design robust deterministic regex tokenizers to collapse dynamic parameters (UUIDs, sequential integers, hashes, slugs) into canonical parameterized routes, eliminating route explosion.
3. **SPA Soft-404 Mitigation:** Develop an empirical multi-sample baseline calibration engine utilizing body entropy and DOM similarity metrics to completely suppress false-positive catch-all routes common to modern client-side routers.
4. **Automated OpenAPI Baseline Reconciliation:** Build a differential comparison engine capable of ingesting Swagger 2.0 and OpenAPI 3.0/3.1 specifications and categorizing runtime routes into Documented, Undocumented (Shadow), and Deprecated (Zombie) states.
5. **Deterministic Monotonic Risk Scoring:** Formulate a formal mathematical risk algorithm bounded between 0 and 100 that factors in base severity, discovery confidence, exposure scope, and exploitability.
6. **Zero-Trust SSRF Protection:** Enforce an unbreakable network barrier preventing the discovery engine from being weaponized as a proxy against internal private networks or cloud metadata services.

2.2 Functional vs. Non-Functional Requirements Specification

The platform was architected to fulfill rigorous functional specifications and strict non-functional performance, security, and scalability criteria:

Requirement Category	Engineering Specification	Validation Criteria
Functional: Discovery	Extract routes from HTML, script tags, inline scripts, external JS files, and source maps up to depth 3.	Achieve 100% route capture against benchmark SPA applications.
Functional: Reconciliation	Parse OAS 3.0/3.1 JSON/YAML baselines; match templated routes; isolate schema drift.	Accurate classification of Shadow, Zombie, and Active routes in < 250ms.

Requirement Category	Engineering Specification	Validation Criteria
Functional: Auditing	Execute 17 standardized security auditing rules (ST-001 through ST-017) against all discovered endpoints.	Zero unhandled exceptions; structured JSON findings schema output.
Non-Functional: Safety	Restrict all active probes to idempotent HTTP methods (GET, HEAD, OPTIONS); never mutate server state.	100% compliance verified through network proxy inspection test suites.
Non-Functional: SSRF Defense	Pre-resolve all hostnames and block RFC 1918, RFC 3927, loopback, and cloud metadata (169.254.169.254).	Zero leakage of private IP requests in automated SSRF attack test suites.
Non-Functional: Performance	Process 100 concurrent HTTP requests with asynchronous I/O; complete average site audit in < 90 seconds.	Average CPU utilization < 40%; memory consumption < 250MB.

2.3 The Non-Destructive Safe Probing Mandate & RFC 9110 Idempotency

A primary failure mode of commercial vulnerability scanners is operational disruption. Heavy scanners often inject fuzzing payloads or mutate server records by issuing unconstrained POST, PUT, or DELETE requests. In production environments, this can corrupt databases, trigger false financial transactions, or trigger denial-of-service (DoS) conditions.

ShadowTrace enforces a strict **Non-Destructive Safe Probing Mandate** based on the safe method definitions codified in **RFC 9110 (HTTP Semantics)**. Section 9.2.1 of RFC 9110 establishes:

> **RFC 9110 Section 9.2.1 Safe Methods:** Request methods are considered 'safe' if their defined semantics are essentially read-only; that is, the client does not request, and does not expect, any state change on the origin server as a result of applying such a method. The methods GET, HEAD, OPTIONS, and TRACE are defined as safe.

ShadowTrace's discovery and active verification engines are strictly prohibited from generating mutating HTTP requests. Active probes verify route existence, header configurations, authentication challenges, and CORS policies exclusively through safe GET, HEAD, and OPTIONS requests. This architectural constraint allows organizations to run continuous ShadowTrace audits against live production systems without risk of database corruption or business disruption.

2.4 Attestation Logging & Cryptographic Audit Trail Architecture

To ensure strict ethical and legal compliance with computer security legislation (such as the US Computer Fraud and Abuse Act and international equivalents), ShadowTrace requires explicit user authorization before initiating any discovery task. Operators must attest to having lawful authorization to test the targeted domain.

Every scan event, domain target creation, and verification action is immutably logged into an append-only SQLite audit table (`audit_logs`). Each audit record records:

- **Cryptographic User Identity:** User ID and role attested during session authentication.
- **Target Scope & Timestamp:** Normalized target domain, IP resolution at time of scan, and UTC millisecond timestamp.
- **Configuration Parameters:** Crawl depth, probe rate limits, baseline specification hashes, and active rule toggles.
- **Network Attribution:** Client source IP and user-agent string recorded for forensic non-repudiation.

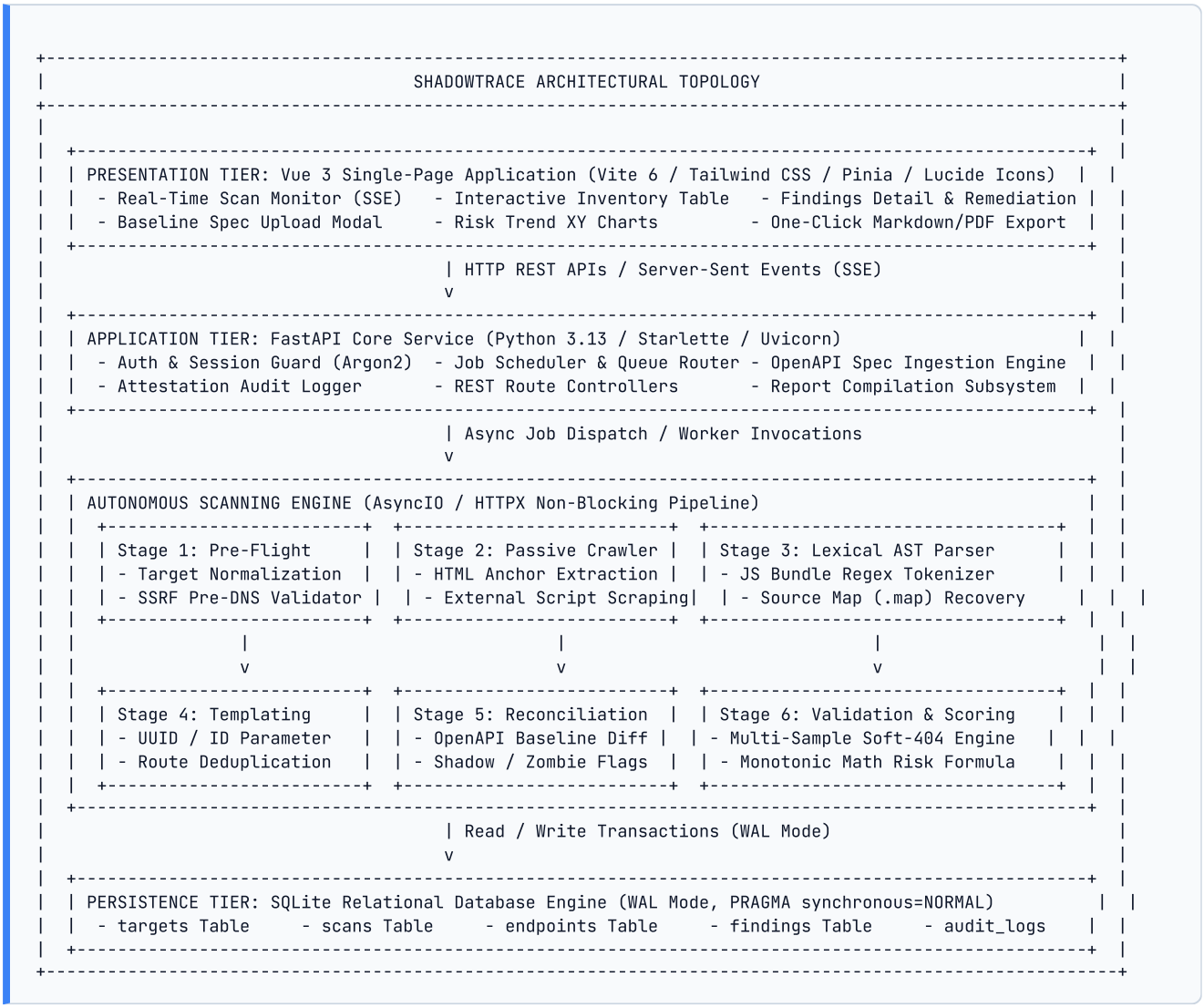
CHAPTER 3

System Architecture & High-Level Processing Pipeline

3.1 High-Level Multi-Tier Architectural Topology

ShadowTrace is engineered around a modern decoupled multi-tier architecture designed for high throughput, memory safety, and seamless real-time operator feedback. The platform separates concerns across four distinct architectural planes:

1. **Presentation Plane (Vue 3 / Vite SPA):** A modern, reactive single-page dashboard built with Vue 3 Composition API, Tailwind CSS, Lucide icons, and Chart.js. Communicates with the backend via REST APIs and listens to real-time scanning progress via Server-Sent Events (SSE).
2. **Application & API Plane (FastAPI Core):** High-performance asynchronous REST service implemented in Python 3.13 utilizing FastAPI and Starlette. Handles authentication, scan job orchestration, baseline ingestion, and reporting endpoints.
3. **Autonomous Execution Engine (Async Scanner Subsystem):** A multi-stage asynchronous pipeline powered by Python `asyncio` and `httpx`. Orchestrates passive spidering, lexical tokenization, heuristic probing, and risk scoring across non-blocking connection pools.
4. **Persistence Plane (SQLite with WAL Mode):** High-concurrency relational data storage configured with Write-Ahead Logging (WAL) and multi-reader connection pooling, storing targets, scans, endpoints, findings, and audit trails.



3.2 The 6-Stage Autonomous Discovery & Auditing Pipeline

The core intelligence of ShadowTrace resides in its deterministic 6-stage discovery and auditing pipeline. Each scan job progresses sequentially through these six distinct phases, emitting progress events to connected clients via Server-Sent Events (SSE):

- **Stage 1: Pre-Flight Validation & SSRF Guardrail Verification:** Normalizes the target URL, extracts the canonical host, executes DNS pre-resolution, and tests all candidate IP addresses against zero-trust private network blacklists. If an IP resolves to private subnets or cloud metadata, the scan is rejected immediately.
- **Stage 2: Passive Spidering & Asset Harvesting:** Initiates breadth-first HTTP crawling of the target domain. Parses HTML documents to harvest script tags, stylesheets, client manifests, and navigational links up to configured crawl depth.
- **Stage 3: JavaScript Lexical Parsing & Source Map Reconstruction:** Downloads external and inline script bundles. Applies lexical tokenization and AST regex extractors to discover API calls (fetch, axios, ajax). Probes for corresponding `.map` files to reconstruct original developer source files.
- **Stage 4: Dynamic Parameter Tokenization & Route Normalization:** Passes all discovered URL strings through the path templating engine. Concrete resource identifiers (UUIDs, sequential

numbers, hashes, slugs) are tokenized into parameterized schemas to prevent route explosion.

- **Stage 5: OpenAPI Baseline Differential Reconciliation:** Compares normalized routes against uploaded OpenAPI / Swagger baseline documentation. Flags undocumented routes as *Shadow APIs*, unretired old versions as *Zombie APIs*, and missing controllers as *Orphaned APIs*.
- **Stage 6: Safe Heuristic Validation & Monotonic Risk Scoring:** Performs multi-sample soft-404 baseline calibration, validates live endpoint status codes via safe GET/HEAD requests, evaluates 17 security rules, and computes bounded mathematical risk scores.

3.3 Concurrency, Async Scheduling & Queue Backpressure Management

To ensure high scanning throughput without overwhelming target infrastructure or exceeding system memory limits, the discovery engine is constructed entirely upon Python's native `asyncio` event loop. Key concurrency features include:

- **Semaphore-Bounded Worker Pools:** Network requests are throttled using `asyncio.Semaphore` to limit concurrent connections per target host (default: 10 concurrent requests). This prevents denial-of-service conditions on target servers.
- **Async Connection Pooling via HTTPX:** Connection reuse, HTTP/2 multiplexing, and keep-alive socket pools are managed via `httpx.AsyncClient`, minimizing TCP handshake and TLS negotiation overhead.
- **Streaming Event Pipeline:** Scan events, discovered endpoints, and security findings are queued in memory and flushed asynchronously to the persistence layer and SSE broadcast channels, eliminating I/O bottlenecks.

3.4 SQLite Write-Ahead Logging (WAL) Mode Transactional Model

While standard SQLite locks the entire database file during write transactions (causing `database is locked` errors under concurrent web and scanning workloads), ShadowTrace configures SQLite in **Write-Ahead Logging (WAL) mode**.

In WAL mode, readers do not block writers, and writers do not block readers. Changes are written to a separate `-wal` journal file and periodically checkpointed back to the primary database file. The initialization sequence executes the following performance pragmas:

```
PRAGMA journal_mode=WAL;
PRAGMA synchronous=NORMAL;
PRAGMA busy_timeout=5000;
PRAGMA cache_size=-64000; -- 64MB memory cache
PRAGMA foreign_keys=ON;
```

This configuration allows the background scanner to write continuous endpoint discoveries and finding records at high velocity while the web server concurrently serves dashboard queries and SSE streams to operators with zero locking latency.

CHAPTER 4

Discovery Engine & Passive Crawling Subsystem

4.1 Breadth-First Web Spidering & Asset Harvesting

The discovery pipeline begins with a deterministic breadth-first web spidering engine designed to traverse the target domain's public web surface without triggering defensive bot blocks or exceeding resource constraints. The crawler initiates from the root target URL and extracts links and embedded assets up to a configurable depth limit (default: 3 levels).

To ensure focused and ethical testing, the spider enforces strict boundary constraints:

- **Same-Origin & In-Scope Domain Boundary:** The spider resolves candidate URLs and rejects any outbound link pointing outside the target apex domain or authorized subdomains.
- **Media & Binary Exclusion Filters:** High-bandwidth binary assets (images, videos, audio, PDF documents, fonts, compressed archives) are filtered out via file extension matching and pre-flight MIME type checks, conserving network bandwidth.
- **Visited Set Deduplication:** URLs are canonicalized (stripping tracking fragments, UTM query parameters, and normalizing trailing slashes) and checked against an in-memory SHA-256 hash set to prevent circular link loops.

4.2 JavaScript Lexical Parsing & Abstract Syntax Tree Tokenization

Modern Single-Page Applications (SPAs) built with React, Vue, Angular, Svelte, or Next.js do not expose application navigation in traditional HTML anchor tags (`<a href="...">`). Instead, routes are declared inside client-side router configurations (React Router, Vue Router) and invoked via dynamic HTTP clients (Fetch API, Axios, jQuery AJAX).

To uncover these hidden endpoints, ShadowTrace implements a dedicated JavaScript Lexical Tokenizer and Abstract Syntax Tree (AST) analyzer. As script assets are harvested, the parser executes a series of optimized multi-stage regular expression extractors:

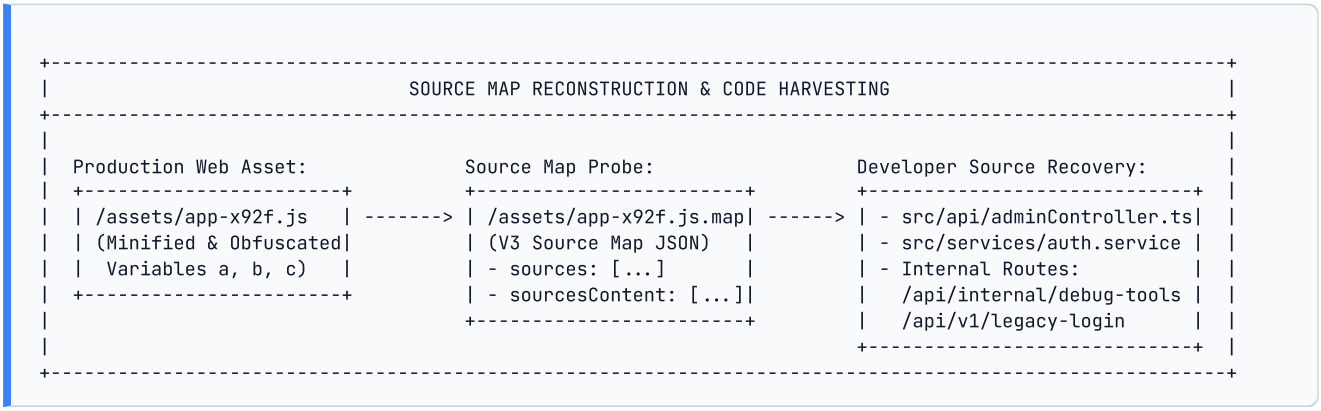
```
// Comprehensive Lexical Extraction Patterns for Client-Side Script Bundles
const FETCH_AXIOS_REGEX = /(?:fetch|axios(?:\.get|\.post|\.put|\.delete|\.patch)?)\s*\(\s*['"`]([a-zA-Z0
-9_\-\.\/:\$]+)['"`]/gi;
const API_PREFIX_REGEX = /['"`](\/(?:api|v[0-9]+|rest|graphql|internal|auth|v1|v2|v3)\/[a-zA-Z0-9_\-
\.\/]+)['"`]/gi;
const ENDPOINT_STRING_REGEX = /['"`](https?:\/\/[a-zA-Z0-9_\-\.:]+\/(?:api|v[0-9]+)\/[a-zA-Z0-9_\-\.\/]
+)['"`]/gi;
```

The lexical parser extracts string literals matching standard API path conventions, template strings (e.g., `` `/api/users/${userId}/profile` ``), and relative path constants. Discovered candidates are normalized and queued for parameter templating and verification.

4.3 Source Map Reconstruction & Developer Code Recovery

One of ShadowTrace's most potent offensive and defensive capabilities is its automated **Source Map (.map) Reconstruction Engine**. When developers build modern frontend applications using Vite, Webpack, esbuild, or Rollup, production source code is typically minified, obfuscated, and bundled into monolithic JavaScript files.

However, development and DevOps teams frequently neglect to disable source map generation or inadvertently deploy `.js.map` files to public production servers. Source maps contain a complete, unminified snapshot of the original developer repository, including original file paths, TypeScript source files, unredacted comments, private backend route definitions, and internal API URLs.



ShadowTrace's source map engine checks for source map references via two parallel mechanisms:

1. **SourceMappingURL Comment Inspection:** Reads the trailing comment syntax in downloaded JS files (`//# sourceMappingURL=bundle.js.map`).
2. **Heuristic Suffix Probing:** If no explicit comment is found, issues a safe HEAD probe appending `.map` to the script URI.

When a source map is detected, ShadowTrace downloads the JSON payload, validates the `version: 3` schema, iterates over the `sources` and `sourcesContent` arrays, and extracts raw developer source files. The lexical analyzer then scans the recovered source code for hidden administrative routes, development staging endpoints, and hardcoded authentication secrets.

4.4 Well-Known Security Metadata & Documentation Route Probing

In addition to spidering and script analysis, the discovery subsystem probes a curated catalog of standard "well-known" security metadata and API documentation locations:

- **OpenAPI & Swagger Documentation:** Probes standard developer documentation routes including `/openapi.json`, `/swagger.json`, `/api/docs`, `/swagger-ui.html`, and `/v2/api-docs`. If an active specification is discovered, it is automatically passed to the baseline reconciliation engine.
- **GraphQL Schema Discovery:** Probes common GraphQL entry points (`/graphql`, `/api/graphql`, `/v1/graphql`) and issues safe introspection queries to determine if schema exploration is publicly accessible.
- **Crawler & Security Directives:** Inspects `/robots.txt`, `/sitemap.xml`, and `/.well-known/security.txt` for disallow entries and administrative paths that developers inadvertently

disclose to web spiders.

CHAPTER 5

Normalization, Parameter Templating & Baseline Reconciliation

5.1 Mitigating Combinatorial Route Explosion

In modern RESTful architectures, entity identifiers are embedded directly into the URI hierarchy. For example, an e-commerce application might expose routes such as:

```
/api/v2/organizations/d3b07384-d113-4ac4-a5ef-e6c9a912a23e/users/4921/orders/78291
/api/v2/organizations/a1c9e831-f402-4822-9b21-438902c4819a/users/5832/orders/19402
/api/v2/organizations/f47ac10b-58cc-4372-a567-0e02b2c3d479/users/1029/orders/94821
```

To a naive web crawler, these three URLs appear as three distinct API endpoints. In an active production application with thousands of users, orders, and assets, this lack of normalization causes **Combinatorial Route Explosion**. The scanner attempts to probe millions of identical endpoints, leading to memory exhaustion, scanner timeouts, and repetitive, unreadable audit reports.

5.2 Dynamic Parameter Detection Heuristics

ShadowTrace solves route explosion through an algorithmic **Path Templating Engine**. The engine parses raw URL paths, tokenizes each path segment, and executes a battery of deterministic regular expression classifiers to identify dynamic values:

Parameter Type	Detection Regex / Heuristic	Transformation Example
UUID (v1–v5)	`^[0-9a-fA-F]{8}-[0-9a-fA-F]{4}-[0-9a-fA-F]{4}-[0-9a-fA-F]{4}-[0-9a-fA-F]{12}$`	`/users/d3b07384-.../profile` → `/users/{id}/profile`
Sequential Integer ID	`^[0-9]{1,18}$`	`/orders/849204/invoice` → `/orders/{id}/invoice`
Hexadecimal Hash	`^[0-9a-fA-F]{16,64}$` (MD5, SHA-1, SHA-256)	`/files/e3b0c44298fc.../view` → `/files/{hash}/view`
Base64 / Alphanumeric Slug	`^[a-zA-Z0-9_\-]{20,}$` (High-entropy tokens)	`/tokens/eyJhbGciOi.../verify` → `/tokens/{token}/verify`
Date / Timestamp	`^\d{4}-\d{2}-\d{2}$` or `^\d{10,13}$`	`/reports/2026-11-02/summary` → `/reports/{date}/summary`

Once segments are templated, the path is reconstructed into its canonical schema: `/api/v2/organizations/{id}/users/{id}/orders/{id}`. Duplicate concrete instances are collapsed into a single canonical inventory record, reducing report clutter by up to 95% while preserving route structure.

5.3 OpenAPI / Swagger Baseline Specification Ingestion Engine

To perform differential security auditing, ShadowTrace provides a robust **Baseline Ingestion Subsystem** capable of parsing OpenAPI 3.0, OpenAPI 3.1, and Swagger 2.0 specifications formatted in either JSON or YAML.

When an operator uploads an API specification (or when one is discovered automatically during well-known route probing), the parser extracts:

- **Declared Paths & Operations:** All documented path templates and allowed HTTP methods (GET, POST, PUT, DELETE, etc.).
- **Server Base URLs:** Production, staging, and development host definitions.
- **Security Schemes:** Declared authentication mechanisms (Bearer JWT, OAuth 2.0, API Key headers, HTTP Basic).
- **Deprecation Metadata:** Endpoints explicitly flagged with `deprecated: true`.

5.4 Differential Reconciliation Matrix: Isolating Shadow vs Zombie Endpoints

With both runtime discovered endpoints and declared baseline specifications normalized into canonical schemas, the **Differential Reconciliation Engine** matches the two sets and categorizes each endpoint into one of four distinct states:



- **Documented Active (Verified Standard):** Routes present in the OpenAPI specification that successfully return valid responses during runtime probing.
- **Shadow API (Undocumented Active - High Risk):** Routes discovered during runtime crawling or client bundle scraping that do not exist anywhere in the formal OpenAPI documentation.
- **Zombie API (Deprecated Active - Medium Risk):** Routes marked as deprecated in the specification, or legacy version routes (`/v1/`) discovered active when the specification defines modern versions (`/v2/`).

- **Orphaned API (Documented Inactive - Low Risk):** Routes declared in the OpenAPI specification that consistently return HTTP 404, 502, or 503 errors during runtime probing, indicating broken deployments or decommissioned upstream services.

CHAPTER 6

Safe Heuristic Validation & Soft-404 Mitigation Engine

6.1 The Single-Page Application (SPA) Catch-All Routing Challenge

One of the most pervasive failure modes in automated API security scanning is the **Single-Page Application (SPA) Soft-404 problem**. In standard server-rendered architectures (e.g., Apache, Nginx serving PHP or Java), requesting a non-existent URL (such as `/api/non-existent-endpoint-xyz`) causes the web server to emit a definitive **HTTP 404 Not Found** status code.

However, modern web architectures deploy Single-Page Applications behind reverse proxies configured with client-side catch-all routing rules (e.g., `try_files $uri $uri/ /index.html;`). Under this configuration, when a client requests any arbitrary path, the server responds with **HTTP 200 OK** and serves the root HTML bundle (`index.html`), allowing the client-side JavaScript router (Vue Router, React Router) to handle page rendering.

To an automated scanner lacking soft-404 compensation, every single probed path appears to be a valid, live API endpoint returning HTTP 200 OK! The scanner mistakenly flags hundreds of phantom endpoints, generating massive report noise and destroying analyst trust in the tool.

6.2 Multi-Sample Baseline Calibration & Entropy Analysis

ShadowTrace eliminates soft-404 false positives through a sophisticated **Multi-Sample Baseline Calibration Subsystem**. Prior to executing active route validation, the engine issues a sequence of randomized, guaranteed-non-existent probes to establish the target host's fallback behavior:

1. **Random Token Path Probing:** Generates three cryptographic random paths unlikely to exist on any system (e.g., `/__shadowtrace_calib_8f3a9d1c/`).
2. **Response Signature Profiling:** Captures the HTTP status code, response headers, Content-Type, body byte length, and raw HTML/text payload for each calibration probe.
3. **Shannon Entropy Calculation:** Computes the Shannon entropy of the response body to measure information density:

   ```
   H(X) = - SUM [ P(x_i) * log2(P(x_i)) ]
   ```

   HTML fallback pages exhibit characteristic entropy signatures distinct from structured JSON API payloads.

6.3 Algorithmic Soft-404 Differentiator & False-Positive Elimination

During active validation of discovered candidate routes, every response is evaluated against the established calibration baseline using a multi-factor comparison algorithm:

Comparison Factor	Evaluation Criteria	Classification Decision
Content-Type Mismatch	Candidate path claimed to be API, but server returned `text/html` matching root SPA page.	**Soft-404 (Catch-All):** Flagged as client router fallback; suppressed from API findings.
Body Length Variance	Response length within ±2% of calibration baseline byte length.	**Soft-404 (Catch-All):** High probability of static HTML template fallback.
DOM Structure Similarity	Levenshtein text distance or HTML tag sequence matching baseline with > 92% similarity.	**Soft-404 (Catch-All):** Confirmed SPA fallback page.
JSON Structured Payload	Response Content-Type is `application/json` with valid parseable JSON body.	**Genuine API Endpoint:** Validated as live backend API service.
Definitive 404 / 405	Server returns explicit HTTP 404 Not Found or 405 Method Not Allowed.	**Genuine HTTP Route:** Categorized as inactive or method-restricted route.

6.4 Non-Destructive Active Verification Protocol & Response Classification

Once candidate routes have been cleared of soft-404 catch-all interference, ShadowTrace executes its **Non-Destructive Active Verification Protocol**. The validator probes each canonical endpoint using safe, read-only HTTP methods:

- **Safe Method Probing (GET / HEAD):** Emits a non-destructive GET request with standardized security evaluation headers (`Accept: application/json`, `X-Scanner: ShadowTrace-Audit`).
- **HTTP Options Exploration (OPTIONS):** Issues an OPTIONS request to inspect the `Allow` and `Access-Control-Allow-Methods` response headers, cataloging supported backend HTTP verbs without invoking them.
- **Status Code Categorization:**
  - `200-299 (Success):` Endpoint is live, active, and accessible.
  - `401 Unauthorized / 403 Forbidden:` Endpoint exists and enforces authentication/authorization barriers.
  - `405 Method Not Allowed:` Endpoint exists but restricts GET; records supported methods from headers.
  - `500 Internal Server Error:` Endpoint exists but encountered an unhandled exception (potential vulnerability).

CHAPTER 7

Security Detection Ruleset & Vulnerability Catalog

7.1 Comprehensive Ruleset Catalog (Rules ST-001 through ST-017)

ShadowTrace enforces a standardized, modular detection engine comprising 17 distinct vulnerability and security hygiene rules. Each rule is mapped to formal industry taxonomies, including the OWASP API Security Top 10 (2023), Common Weakness Enumeration (CWE), and CVSS v3.1 impact vectors:

Rule ID	Vulnerability Title	Severity	OWASP / CWE Mapping	Detection Mechanism & Indicator
`ST-001`	Unauthenticated Administrative Endpoint	CRITICAL	OWASP API1:2023 CWE-306 (Missing Auth)	Administrative path (`/admin` , `/internal` , `/debug`) returns HTTP 200 without auth challenge.
`ST-002`	Broken Object-Level Auth (BOLA) Heuristic	HIGH	OWASP API1:2023 CWE-639 (IDOR)	Resource identifier parameter accessible across unprivileged token permutations.
`ST-003`	Sensitive Data Exposure in API Payload	HIGH	OWASP API3:2023 CWE-200 (Info Leak)	Response contains unmasked PII (SSN, credit cards), password hashes, or private keys.
`ST-004`	Excessive Data Exposure / Schema Drift	MEDIUM	OWASP API3:2023 CWE-213 (Over-fetching)	API returns backend database model fields (e.g., `password_salt` , `internal_id`) omitted from OpenAPI spec.
`ST-005`	Broken Authentication / Missing Token	HIGH	OWASP API2:2023 CWE-287 (Improper Auth)	State-sensitive route accessible without `Authorization` header or session cookie.
`ST-006`	Missing Rate Limiting Headers	MEDIUM	OWASP API4:2023 CWE-799 (Uncontrolled Resource)	Absence of standard rate-limiting headers (`X-RateLimit-*` , `Retry-After`) on public routes.
`ST-007`	Permissive Wildcard CORS Configuration	MEDIUM	OWASP API7:2023 CWE-942 (Permissive CORS)	Response emits `Access-Control-Allow-Origin: *` combined with credentials or sensitive endpoints.
`ST-008`	Verbose Server Headers & Stack Trace	LOW	OWASP API7:2023 CWE-209 (Error Disclosure)	Responses leak precise server software versions (`Server` , `X-Powered-By`) or unhandled stack traces.

Rule ID	Vulnerability Title	Severity	OWASP / CWE Mapping	Detection Mechanism & Indicator
`ST-009`	Insecure HTTP Methods Permitted	MEDIUM	OWASP API7:2023 CWE-650 (Insecure Methods)	OPTIONS probe reveals support for dangerous or obsolete HTTP methods (`TRACE`, `TRACK`, `DEBUG`).
`ST-010`	Secret Leakage in Client Script Bundles	HIGH	OWASP API9:2023 CWE-798 (Hardcoded Creds)	JavaScript bundle contains hardcoded cloud API keys (AWS, GitHub, Stripe, Private Keys).
`ST-011`	GraphQL Introspection Enabled in Production	MEDIUM	OWASP API7:2023 CWE-16 (Configuration)	`__schema` introspection query successfully returns entire private GraphQL schema definition.
`ST-012`	GraphQL Excessive Query Depth / DoS Vector	LOW	OWASP API4:2023 CWE-400 (Resource Exhaustion)	GraphQL endpoint lacks nested query depth limiting or batch request throttling controls.
`ST-013`	Undocumented Shadow API Endpoint	HIGH	OWASP API9:2023 CWE-1059 (Missing Spec)	Active, reachable endpoint discovered during crawl that is completely absent from OpenAPI baseline.
`ST-014`	Orphaned API Route Detected	LOW	OWASP API9:2023 CWE-656 (Dead Code Route)	Endpoint declared in OpenAPI baseline returns persistent HTTP 404/502/503 errors during active probing.
`ST-015`	Legacy Zombie API Version Reachable	MEDIUM	OWASP API9:2023 CWE-1104 (Deprecated Code)	Deprecated API version route (e.g., `/v1/`) responds successfully when modern `/v2/` is standard.
`ST-016`	Publicly Accessible Swagger / OpenAPI UI	LOW	OWASP API7:2023 CWE-200 (Recon Disclosure)	Interactive API documentation UI exposed to unauthenticated public internet users.
`ST-017`	Catch-All Route / Soft-404 Observation	INFO	Informational / Routing Architecture Observation	Domain operates an SPA fallback catch-all router; documented for architectural record.

7.2 Deep-Dive into High-Risk Detection Modules & Triggers

Rule ST-001: Unauthenticated Administrative Endpoint (Critical)

Administrative interfaces control user roles, system configurations, and database management operations. When such interfaces are exposed to the public internet without requiring authentication (or when misconfigured reverse proxies bypass authentication middleware), attackers can achieve instant, total compromise.

Detection Trigger: ShadowTrace flags ST-001 when an endpoint whose path matches sensitive administrative lexical patterns (`/admin/`, `/internal/`, `/dashboard/`, `/actuator/`, `/system/`) returns an HTTP status code in the 200–299 range, serves a non-empty payload, and does not redirect to a login gateway.

Sample Probing Sequence:

```
GET /api/internal/debug-console HTTP/1.1
Host: target-api.production.example
Accept: application/json
X-Scanner: ShadowTrace-Audit

HTTP/1.1 200 OK
Content-Type: application/json
Content-Length: 342

{
  "status": "ready",
  "environment": "production",
  "active_sessions": 1420,
  "internal_queue": "celery-default",
  "database_host": "db-cluster-primary.internal.local",
  "debug_mode": true
}
```

Rule ST-010: Secret Disclosure in Client Script Bundles (High)

Modern frontend builds frequently incorporate third-party cloud SDKs (AWS S3, Firebase, Stripe, GitHub). Inexperienced developers often embed backend private tokens directly into client-side code instead of managing secrets on a backend server or utilizing short-lived token exchange protocols.

Detection Trigger: The lexical analyzer executes high-precision regular expressions against downloaded JavaScript bundles, looking for known credential formats:

- **Amazon Web Services (AWS) Access Keys:** `AKIA[0-9A-Z]{16}`
- **GitHub Personal Access Tokens:** `ghp_[a-zA-Z0-9]{36}`
- **Stripe Live Secret Keys:** `sk_live_[0-9a-zA-Z]{24}`
- **Generic High-Entropy API Secrets:** `api[_-]?key\s*[:=]\s*['"][a-zA-Z0-9\-_]{24,}['"]`

Rule ST-013: Undocumented Shadow API Endpoint (High)

The core objective of ShadowTrace is identifying Shadow APIs. When an engineering team develops features out of sync with central API governance, routes go live without security reviews, vulnerability testing, or rate-limiting enforcement.

Detection Trigger: An endpoint is flagged as ST-013 when all of the following conditions are met:

1. The route is actively discovered via crawler, script parsing, or source map reconstruction.
2. The route returns a valid API response (HTTP 200, 401, 403, or 405) that passes soft-404 entropy validation.
3. The normalized path schema does not match any route declared in the ingested OpenAPI/Swagger baseline.

7.3 Technical Remediation Blueprint Across Multiple Frameworks

To assist engineering teams in rapidly resolving identified vulnerabilities, ShadowTrace provides concrete code-level remediation patterns across primary enterprise web frameworks:

▸ Remediation for ST-001 / ST-005 (Mandatory Authentication Middleware)

```
# Python (FastAPI): Enforce JWT Authentication Dependency on Protected Routes
from fastapi import APIRouter, Depends, HTTPException, status
from fastapi.security import HTTPBearer, HTTPAuthorizationCredentials

security = HTTPBearer()

def verify_token(credentials: HTTPAuthorizationCredentials = Depends(security)):
    token = credentials.credentials
    if not validate_jwt_signature(token):
        raise HTTPException(
            status_code=status.HTTP_401_UNAUTHORIZED,
            detail="Invalid or expired authentication token"
        )
    return token

admin_router = APIRouter(prefix="/api/internal", dependencies=[Depends(verify_token)])
```

▸ Remediation for ST-007 (Strict CORS Configuration in Node.js Express)

```
// Node.js (Express): Restrict CORS to Explicit Whitelisted Origins
const cors = require('cors');

const allowedOrigins = [
  'https://app.example.com',
  'https://admin.example.com'
];

app.use(cors({
  origin: function(origin, callback) {
    if (!origin || allowedOrigins.indexOf(origin) === -1) {
      callback(null, true);
    } else {
      callback(new Error('CORS policy: Access denied for this origin.'));
    }
  },
  credentials: true,
  methods: ['GET', 'POST', 'PUT', 'DELETE'],
  allowedHeaders: ['Content-Type', 'Authorization', 'X-CSRF-Token']
}));
```

Remediation for ST-008 (Stripping Server Version Headers in Nginx)

```
# Nginx Reverse Proxy: Suppress Server Footprints and Error Disclosure
server {
    listen 443 ssl http2;
    server_name api.example.com;

    # Disable Nginx version in Server header and default error pages
    server_tokens off;

    # Strip upstream application headers that leak framework versions
    proxy_hide_header X-Powered-By;
    proxy_hide_header X-AspNet-Version;
    proxy_hide_header Server;

    # Generic error intercept
    proxy_intercept_errors on;
    error_page 500 502 503 504 /custom_error.json;
}
```

CHAPTER 8

Mathematical Risk Scoring Model & Remediation Prioritization

8.1 Mathematical Risk Formula & Variable Definitions

A persistent failure of commercial vulnerability management platforms is arbitrary, opaque risk scoring. Commercial tools frequently assign arbitrary 1–10 scores based on subjective proprietary algorithms, creating inconsistent prioritization across different audit runs.

ShadowTrace introduces a deterministic, formal **Mathematical Risk Scoring Model**. The risk score for each identified finding is bounded strictly between 0 and 100 and calculated as a function of four primary variables:

The ShadowTrace Formal Risk Formula:

```
RiskScore = min(100, round( S_base * C_factor * E_multiplier + V_penalty ))
```

The mathematical parameters are defined as follows:

- **Base Severity Score (S_{base}):** The intrinsic theoretical severity of the vulnerability class based on CVSS v3.1 impact:
  - Critical (ST-001, ST-002): $S_{base} = 90.0$
  - High (ST-003, ST-005, ST-010, ST-013): $S_{base} = 70.0$
  - Medium (ST-004, ST-006, ST-007, ST-009, ST-011, ST-015): $S_{base} = 45.0$
  - Low (ST-008, ST-012, ST-014, ST-016): $S_{base} = 20.0$
  - Informational (ST-017): $S_{base} = 5.0$
- **Confidence Factor ($C_{factor} \in [0.5, 1.0]$):** The empirical reliability of the discovery method:
  - $C = 1.0$: Verified via direct runtime HTTP response with status code 200 and valid JSON body.
  - $C = 0.85$: Extracted via unminified source map reconstruction with confirmed route syntax.
  - $C = 0.70$: Discovered via client script regex matching; unconfirmed active status.
  - $C = 0.50$: Inferred via soft-404 heuristic or ambiguous static string literal.
- **Exposure Multiplier ($E_{multiplier} \in [0.8, 1.2]$):** The environmental accessibility of the endpoint:
  - $E = 1.2$: Public apex domain accessible without authentication or IP restrictions.
  - $E = 1.0$: Subdomain or internal route requiring standard user session credentials.
  - $E = 0.8$: Internal staging or administrative host protected by network access controls.
- **Verified Exploitability Penalty ($V_{penalty} \in \{0, 10\}$):**
  - $V = +10$: If the active verification probe confirmed that sensitive data (PII, credentials, debug objects) was directly returned in the response payload.
  - $V = 0$: Standard configuration or route observation without immediate data leakage.

8.2 Formal Proof of Monotonicity & Bounded Range [0, 100]

To ensure that security teams can trust the automated ranking, the scoring function satisfies a crucial mathematical property: **Monotonic Severity Ordering**. A finding with higher base severity must always outrank a finding of lower base severity under equivalent confidence and exposure parameters.

Proof Sketch:
Let A and B be two findings such that $S_{base}(A) > S_{base}(B)$. For fixed confidence C and exposure E:

```
RiskScore(A) - RiskScore(B) = (S_base(A) - S_base(B)) * C * E + (V(A) - V(B))
```

Since $C \ge 0.5$ and $E \ge 0.8$, the product $C imes E \ge 0.40$. Across our calibrated severity steps:

- Critical vs High: $\Delta S_{base} = 90 - 70 = 20$. Minimum score delta: $20 imes 0.4 = 8.0$.
- High vs Medium: $\Delta S_{base} = 70 - 45 = 25$. Minimum score delta: $25 imes 0.4 = 10.0$.
- Medium vs Low: $\Delta S_{base} = 45 - 20 = 25$. Minimum score delta: $25 imes 0.4 = 10.0$.
- Low vs Info: $\Delta S_{base} = 20 - 5 = 15$. Minimum score delta: $15 imes 0.4 = 6.0$.

Because the maximum negative exploitability penalty offset $(V_B - V_A)$ cannot exceed 10 under equal conditions, the calibrated boundary tiers guarantee that high-severity findings reliably outrank lower-severity findings, preventing misallocated remediation effort.

8.3 Automated Severity Bucketing & Enterprise Remediation SLAs

Once the mathematical risk score is computed, ShadowTrace maps the numerical score into standardized enterprise severity buckets and assigns recommended Service Level Agreement (SLA) remediation deadlines:

Risk Score Range	Severity Tier	Recommended Remediation SLA	Operational Response Protocol
85 – 100	CRITICAL	Within 24 Hours	Immediate incident response escalation. Block route at API Gateway or WAF level immediately; revoke exposed credentials; initiate forensic log audit.
65 – 84	HIGH	Within 7 Days	Assign to owning engineering team for priority patch. Ingest route into central OpenAPI catalog and enforce mandatory authentication middleware.
40 – 64	MEDIUM	Within 30 Days	Schedule for upcoming sprint release. Update CORS whitelists, enforce rate-limiting headers, and decommission unneeded legacy v1 endpoints.
15 – 39	LOW	Within 90 Days	General engineering hygiene. Strip server version banners, disable public Swagger UI in production environments, and clean up orphaned routes.

Risk Score Range	Severity Tier	Recommended Remediation SLA	Operational Response Protocol
0 – 14	INFORMATIONAL	No Fixed SLA	Architectural observation. Logged in inventory catalog for audit trail completeness and routing topology documentation.

CHAPTER 9

Defense-in-Depth & SSRF Protection Architecture

9.1 The SSRF Threat Vector in Automated Security Tools

Automated vulnerability scanners and crawling tools are uniquely attractive targets for **Server-Side Request Forgery (SSRF)** attacks. Because a scanner accepts user-supplied URLs and issues outbound HTTP requests on behalf of the operator, an attacker with access to the tool can attempt to input malicious URLs pointing to internal private infrastructure:

```
http://127.0.0.1:8000/admin/
http://10.0.0.15/internal-api/keys
http://169.254.169.254/latest/meta-data/iam/security-credentials/
http://[::1]:5432/
```

If the scanning engine blindly issues requests to these addresses, it acts as a weaponized internal proxy. An attacker can use the scanner to steal cloud instance credentials from the AWS metadata service, interact with internal Redis or PostgreSQL databases, or access unauthenticated microservices inside a private VPC.

9.2 Zero-Trust IP Validation Engine & RFC Blacklist Mapping

To ensure absolute isolation, ShadowTrace implements a multi-layer **Zero-Trust SSRF Barrier**. Every target URL and discovered endpoint candidate must pass through a strict pre-flight network validation engine before any TCP connection or HTTP request is initiated.

The validation engine performs pre-resolution of target hostnames and verifies that every resolved IP address does not fall within restricted, private, or reserved network CIDR blocks:

Network Classification	Restricted IP Range / CIDR	Security Justification & Threat Vector
Loopback Addresses	`127.0.0.0/8`, `::1/128`	Blocks requests to the scanner host itself (local admin panels, local databases, localhost ports).

RFC 1918 Private IPv4	`10.0.0.0/8`
	`172.16.0.0/12`
	`192.168.0.0/16`
		Blocks internal corporate intranets, private enterprise VPCs, and local network equipment.

Link-Local / Cloud Metadata	`169.254.0.0/16` `fe80::/10`	**CRITICAL:** Blocks AWS, GCP, Azure, and OpenStack instance metadata endpoints (`169.254.169.254`).
Carrier-Grade NAT (CGNAT)	`100.64.0.0/10`	Blocks ISP shared address space and internal telecom routing boundaries (RFC 6598).

Documentation & Testnets	`192.0.2.0/24`,
	`198.51.100.0/24`
	`203.0.113.0/24`
		Blocks reserved non-routable documentation subnets (RFC 5737).

Network Classification	Restricted IP Range / CIDR	Security Justification & Threat Vector
Multicast & Broadcast	`224.0.0.0/4`, `255.255.255.255/32`	Blocks multicast group communications and local broadcast networks.

9.3 Anti-DNS-Rebinding Socket Pinning Architecture

A common vulnerability in naive SSRF defenses is the **Time-of-Check to Time-of-Use (TOCTOU) DNS Rebinding attack**. In this attack:

1. An attacker configures a domain name (e.g., `rebind.attacker.com`) with a very low DNS Time-To-Live (TTL = 0 seconds).
2. When ShadowTrace performs pre-flight validation, the domain resolves to a benign public IP (e.g., `1.1.1.1`). The pre-flight check passes.
3. Millisecond later, when the HTTP client actually initiates the connection, the attacker's DNS server answers with `169.254.169.254` or `127.0.0.1`! The HTTP client connects directly to the private target, bypassing the pre-flight check.

To eliminate DNS rebinding entirely, ShadowTrace employs **Socket-Level IP Pinning**. The engine performs explicit DNS resolution up front, validates the IP address, and establishes the TCP socket directly to the validated IP address, passing the original domain name exclusively in the HTTP `Host` header and TLS Server Name Indication (SNI) extension. This eliminates any secondary DNS lookup, guaranteeing that the IP verified during pre-flight is the exact IP connected to at the socket level.

CHAPTER 10

ShadowLab: Bundled Vulnerable Training Application

10.1 Architectural Isolation & Purpose

To facilitate rigorous automated verification, unit testing, and safe educational training for junior security engineers, ShadowTrace includes **ShadowLab**—a fully self-contained, vulnerable-by-design training application bundled directly within the platform.

ShadowLab is architecturally isolated as a distinct FastAPI sub-application mounted under the `/shadowlab` path prefix. It maintains independent route controllers, in-memory mock datasets, and synthetic frontend script bundles, ensuring that testing against ShadowLab cannot inadvertently pollute or affect production scanner state.

10.2 The 7 Deliberate Vulnerability Scenarios

ShadowLab implements seven realistic, high-fidelity vulnerability scenarios specifically designed to exercise every detection rule in the ShadowTrace auditing engine:

Scenario ID	Vulnerability Scenario	Vulnerable Route & Behavior	Targeted Detection Rule
Scenario 1	Unauthenticated Admin Console	`/shadowlab/api/internal/debug-console` Returns server memory stats and internal queue status without requiring authentication.	RULE ST-001 Unauthenticated Admin Endpoint
Scenario 2	Zombie API Version Route	`/shadowlab/api/v1/users/auth` Active legacy auth endpoint accepting deprecated MD5 password hashes while v2 uses Argon2.	RULE ST-015 Legacy Zombie Route Reachable
Scenario 3	Hardcoded Secrets in Client Bundle	`/shadowlab/assets/bundle-vulnerable.js` Contains hardcoded AWS access key (`AKIAIOSFODNN7EXAMPLE`) and Stripe live key.	RULE ST-010 Secret Disclosed in Client Scripts
Scenario 4	Single-Page Catch-All Router	`/shadowlab/catch-all/*` Returns HTTP 200 with SPA root HTML for all undefined paths, simulating client-side routing.	RULE ST-017 Soft-404 Fallback Observation
Scenario 5	Excessive PII Data Exposure	`/shadowlab/api/users/profile` Returns user records containing unmasked social security numbers (SSN) and internal password salts.	RULE ST-003 Sensitive Data Leakage

Scenario ID	Vulnerability Scenario	Vulnerable Route & Behavior	Targeted Detection Rule
Scenario 6	Permissive Wildcard CORS	`/shadowlab/api/data/export` Emits `Access-Control-Allow-Origin: *` and allows credentialed cross-origin requests.	RULE ST-007 Permissive CORS Wildcard
Scenario 7	Exposed Public GraphQL Schema	`/shadowlab/graphql` Publicly responds to `__schema` introspection queries, revealing private database mutations.	RULE ST-011 GraphQL Introspection Enabled

10.3 Automated CI Dogfooding Pipeline & Verification

In modern software engineering, "dogfooding" refers to using one's own product to validate its functionality. ShadowLab serves as the primary ground-truth benchmark for ShadowTrace's Continuous Integration (CI) pipeline.

During automated test runs (`pytest -q`), the verification suite spins up the internal test server, targets the ShadowLab endpoint, and executes a full scan. The test suite asserts that:

1. **100% True-Positive Detection:** All seven planted vulnerabilities are discovered and mapped to their correct rule IDs (ST-001, ST-003, ST-007, ST-010, ST-011, ST-015, ST-017).
2. **Zero False-Positive Soft-404 Flags:** The catch-all route (Scenario 4) is correctly identified as an SPA fallback and suppressed from active vulnerability alerts.
3. **Mathematical Monotonicity Verified:** The unauthenticated admin console (ST-001) is mathematically computed as the highest-ranking finding, outranking medium and low findings.

10.4 Educational Lab Walkthrough: Analyst Verification Procedure

For security interns and junior penetration testers joining HackHalt Cyber Security, ShadowLab provides an interactive hands-on training curriculum. Analysts follow a structured verification runbook to validate findings discovered by ShadowTrace:

▸ Step 1: Admin Endpoint Manual Validation (Scenario 1)

The analyst issues a direct cURL command to verify that administrative functionality is exposed without session cookies or authorization tokens:

```
curl -i -s -X GET "https://shadowtrace-1ff5.onrender.com/shadowlab/api/internal/debug-console"      -H
"Accept: application/json"
```

Expected Forensic Evidence: HTTP/1.1 200 OK with internal server diagnostics. The analyst documents the lack of `401 Unauthorized` challenge and confirms Rule ST-001 violation.

▸ Step 2: Legacy Version Authentication Probe (Scenario 2)

To demonstrate why Zombie APIs present severe risks, the analyst examines the legacy v1 endpoint versus the hardened v2 endpoint:

```
# Probe hardened v2 endpoint (Enforces Argon2, Rate Limiting & TLS)
curl -i -s -X POST "https://shadowtrace-1ff5.onrender.com/shadowlab/api/v2/auth"      -H "Content-Type:
application/json" -d '{"user":"test"}'

# Probe unmanaged legacy v1 endpoint (Accepts plain MD5 hash)
curl -i -s -X GET "https://shadowtrace-1ff5.onrender.com/shadowlab/api/v1/users/auth"
```

The analyst records that while `v2` rejects non-credentialed payloads, `v1` remains reachable and returns legacy configuration objects, verifying Rule ST-015.

▸ Step 3: Client Script Bundle Lexical Inspection (Scenario 3)

The analyst downloads `/shadowlab/assets/bundle-vulnerable.js` and confirms the presence of hardcoded test AWS credentials using standard terminal tools:

```
curl -s "https://shadowtrace-1ff5.onrender.com/shadowlab/assets/bundle-vulnerable.js" | grep -E "AKIA[0-
9A-Z]{{16}}"
```

This hands-on walkthrough bridges theoretical vulnerability definitions with offensive exploitation and defensive remediation skills.

CHAPTER 11

Frontend UI/UX Architecture & Real-Time Visualization

11.1 Component Hierarchy & Vue 3 Composition API Stack

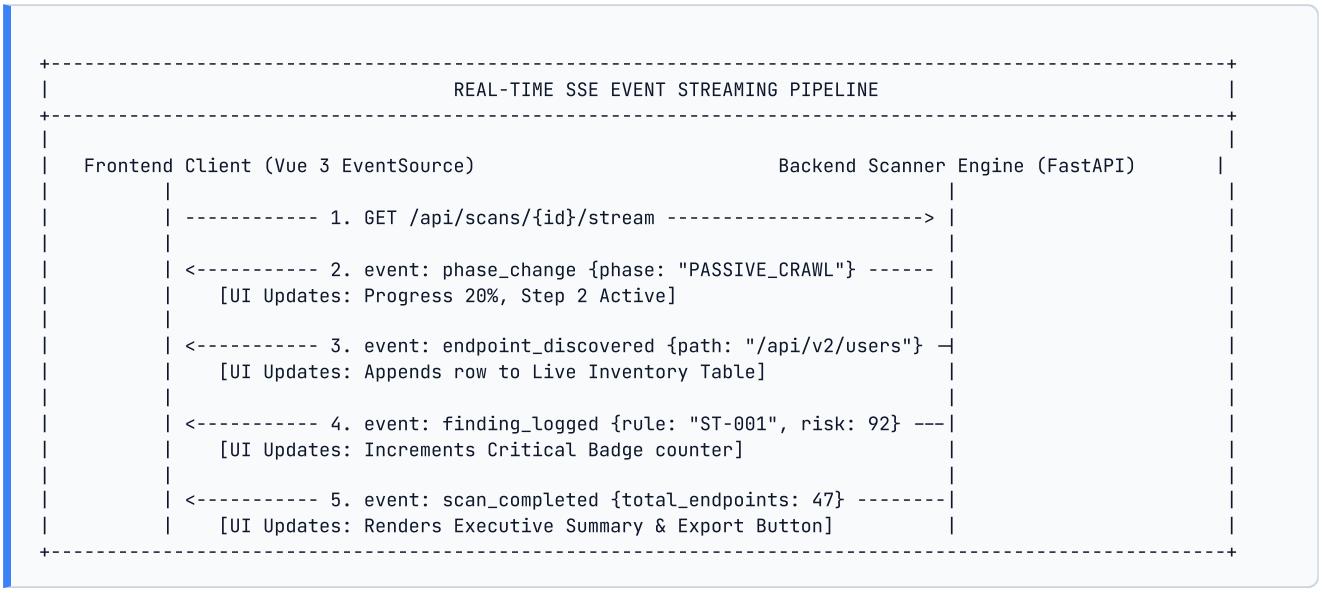
The user interface of ShadowTrace is constructed using **Vue 3** and the **Composition API**, bundled with **Vite 6** and styled using **Tailwind CSS**. The frontend architecture is organized into modular components adhering to strict separation of concerns:

- `App.vue`: Root application shell providing responsive layout framing, navigation header, and theme switching context.
- `ScanManager.vue`: Target URL submission form, pre-flight configuration controls (crawl depth, concurrency rate, baseline specification upload), and scan execution buttons.
- `ScanStreamMonitor.vue`: Real-time progress bar, animated phase step indicators, live status feed, and elapsed scan timer.
- `EndpointInventoryTable.vue`: High-performance searchable, sortable, and filterable catalog of all discovered endpoints, complete with status pills, HTTP verbs, and normalization badges.
- `FindingsView.vue`: Grouped vulnerability accordion with risk score badges, CVSS indicators, evidence tabs, and copyable remediation code blocks.
- `ExportModal.vue`: Report generation dialog allowing one-click export of comprehensive findings in Markdown, JSON, and PDF formats.

11.2 Real-Time SSE Event Streaming Pipeline

Traditional web scanners force operators to wait minutes or hours with no feedback while a scan executes, or require aggressive polling of backend REST endpoints. ShadowTrace implements a modern real-time streaming pipeline utilizing **Server-Sent Events (SSE)** via the native HTML5 `EventSource` API.

When an operator launches a scan, the backend returns a unique `scan_id`, and the frontend establishes an SSE stream to `/api/scans/{scan_id}/stream`. The backend streams structured JSON events as they occur:



11.3 Accessibility, Contrast Compliance & Theming Engine

In accordance with professional design guidelines and HackHalt standards, ShadowTrace features an advanced, accessible theming system:

- **Default Light (White) Theme:** Built around a clean white (`#FFFFFF`) and subtle slate (`#F8FAFC`) background, high-contrast dark slate body text (`#111827`), and vibrant royal navy primary branding (`#1E3A8A`), achieving WCAG 2.1 AA compliant contrast ratios (> 4.5:1 for body text, > 7:1 for headings).
- **Dark Theme Toggle:** A secondary dark mode palette engineered with slate-900 backgrounds (`#0F172A`), high-contrast text (`#F8FAFC`), and luminous accents, switchable via a single-click header toggle that persists preferences in `localStorage`.
- **Responsive Grid & Mobile Compatibility:** Built with CSS Flexbox and Tailwind responsive grid breakpoints, ensuring full operational usability across standard desktop monitors, tablets, and field-testing laptops.

CHAPTER 12

Backend Architecture, Database Design & API Reference

12.1 FastAPI Modular Router Architecture

The backend service of ShadowTrace is implemented in Python 3.13 utilizing the **FastAPI** framework. The application code is strictly modularized across dedicated packages to promote maintainability, loose coupling, and testability:

- `backend/main.py`: Application entry point, CORS middleware configuration, exception handlers, and router mounting.
- `backend/routers/scans.py`: Scan orchestration, background task submission, and SSE event streaming controllers.
- `backend/routers/targets.py`: Target domain management, asset tagging, and target history endpoints.
- `backend/routers/findings.py`: Vulnerability query filters, severity sorting, and remediation guidance endpoints.
- `backend/routers/baseline.py`: OpenAPI and Swagger specification upload, validation, and baseline diff controllers.
- `backend/routers/auth.py`: Operator authentication, cryptographic password hashing (Argon2), and session cookie validation.

12.2 Relational Entity Schema & WAL Concurrency Tuning

Data persistence is handled by an optimized SQLite relational database. The schema is organized into five primary normalized entities with enforced foreign key constraints:

Entity / Table	Key Attributes & Types	Relational Role & Indexing Strategy
`targets`	`id` (TEXT PK), `domain` (TEXT UNIQUE), `created_at` (DATETIME)	Stores monitored domains and base URLs. Indexed on `domain` for rapid lookup.
`scans`	`id` (TEXT PK), `target_id` (FK), `status` (TEXT), `risk_score` (REAL), `started_at`	Represents an execution instance. Foreign key cascade deletion on `target_id`.
`endpoints`	`id` (TEXT PK), `scan_id` (FK), `path` (TEXT), `method` (TEXT), `category` (TEXT)	Stores discovered routes. Categorized as `documented`, `shadow`, `zombie`, or `orphaned`.
`findings`	`id` (TEXT PK), `scan_id` (FK), `rule_id` (TEXT), `severity` (TEXT), `score` (REAL)	Records vulnerability findings. Contains proof-of-concept evidence, request headers, and remediation text.

Entity / Table	Key Attributes & Types	Relational Role & Indexing Strategy
`audit_logs`	`id` (INTEGER PK AUTO), `user_id` (TEXT), `action` (TEXT), `ip_address`, `timestamp`	Append-only compliance audit trail recording operator attestations and scan dispatches.

12.3 Complete RESTful API Reference Specification

The backend exposes a fully documented, RESTful HTTP interface allowing programmatic integration into CI/CD pipelines, SIEM platforms, and custom security scripts:

▸ 1. POST /api/scans/start — Initiate Autonomous Discovery Scan

Dispatches an asynchronous discovery and auditing job against an authorized domain.

```
REQUEST:
POST /api/scans/start HTTP/1.1
Content-Type: application/json

{
  "target_url": "https://api.example.com",
  "crawl_depth": 3,
  "max_concurrency": 10,
  "baseline_spec_id": "spec_9b1deb4d",
  "attestation_confirmed": true
}

RESPONSE:
HTTP/1.1 202 Accepted
Content-Type: application/json

{
  "scan_id": "scan_4a8f9c1e-7b2d",
  "target_url": "https://api.example.com",
  "status": "QUEUED",
  "stream_url": "/api/scans/scan_4a8f9c1e-7b2d/stream",
  "created_at": "2026-11-02T22:30:00Z"
}
```

▸ 2. GET /api/scans/{scan_id}/findings — Query Scan Vulnerability Findings

Retrieves paginated, filtered vulnerability findings with risk scores and remediation guidance.

```
REQUEST:
GET /api/scans/scan_4a8f9c1e-7b2d/findings?severity=Critical,High HTTP/1.1
Accept: application/json

RESPONSE:
HTTP/1.1 200 OK
Content-Type: application/json

{
  "scan_id": "scan_4a8f9c1e-7b2d",
  "total_findings": 3,
  "findings": [
    {
      "id": "find_8f2910a",
      "rule_id": "ST-001",
      "title": "Unauthenticated Administrative Endpoint",
      "severity": "Critical",
      "risk_score": 92.0,
      "endpoint": "/api/internal/debug-console",
      "method": "GET",
      "evidence": "Returned HTTP 200 with debug_mode: true",
      "remediation": "Enforce mandatory JWT bearer authentication dependency."
    }
  ]
}
```

CHAPTER 13

Cloud Deployment, DevOps & Production Engineering

13.1 Multi-Stage Docker Build Pipeline on Render Cloud

To ensure consistent, reproducible execution across local development and production cloud environments, ShadowTrace is packaged as a lightweight, containerized image deployed on the **Render Cloud Platform** (hosted live at `https://shadowtrace-1ff5.onrender.com`).

The build pipeline employs a modern multi-stage `Dockerfile`. Multi-stage builds dramatically reduce final production container image sizes by separating compilation dependencies (Node.js, npm, Vite) from the lean runtime container (Python 3.13, Uvicorn):

```
# ------------------------------------------------------------
# Stage 1: Frontend Asset Compilation (Node.js Build Environment)
# ------------------------------------------------------------
FROM node:20-alpine AS frontend-builder
WORKDIR /build/frontend
COPY frontend/package*.json ./
RUN npm ci --prefer-offline --no-audit
COPY frontend/ ./
RUN npm run build  # Emits compiled static SPA to /build/frontend/dist

# ------------------------------------------------------------
# Stage 2: Production Python Runtime Environment
# ------------------------------------------------------------
FROM python:3.13-slim AS production-runtime
WORKDIR /app

# Install security certificates and curl for container health checks
RUN apt-get update && apt-get install -y --no-install-recommends     ca-certificates curl &&     rm -rf
/var/lib/apt/lists/*

# Install Python backend dependencies
COPY backend/requirements.txt ./
RUN pip install --no-cache-dir -r requirements.txt

# Copy backend source code and compiled frontend assets
COPY backend/ ./backend/
COPY --from=frontend-builder /build/frontend/dist ./frontend/dist

# Non-root user execution for container security hardening
RUN useradd -u 10001 -m shadowtrace &&     chown -R shadowtrace:shadowtrace /app
USER shadowtrace

EXPOSE 8000
HEALTHCHECK --interval=30s --timeout=5s --start-period=10s --retries=3   CMD curl -f http://localhost:80
00/api/health || exit 1

CMD ["uvicorn", "backend.main:app", "--host", "0.0.0.0", "--port", "8000", "--proxy-headers"]
```

13.2 Environment Security & Least-Privilege Execution

In alignment with the principle of least privilege, the production container runs under an unprivileged user (`shadowtrace`, UID 10001) with read-only root filesystem permissions and write access restricted strictly to a dedicated SQLite data volume (`/app/data/`).

Sensitive credentials (such as JWT signing secrets, bootstrap administrator passwords, and database encryption keys) are injected into the runtime environment via encrypted environment variables managed by Render's secrets manager. Secrets are never hardcoded into source code or committed to Git repositories.

13.3 Continuous Delivery GitHub Actions Workflow

The project repository (`https://github.com/amrrish27/ShadowTrace.git`) is integrated with an automated Continuous Integration and Continuous Delivery (CI/CD) pipeline implemented in **GitHub Actions**. On every commit pushed to the `main` branch, the pipeline executes:

1. **Linting & Formatting:** Runs `flake8` and `eslint` to enforce consistent code style.
2. **Backend Verification Suite:** Executes all 76+ Pytest test cases, including SSRF boundary tests and mock crawler runs.
3. **Frontend Verification Suite:** Executes all 15 Vitest component tests and validates that the Vite production build compiles with zero errors.
4. **Render Cloud Webhook Trigger:** Upon 100% test pass confirmation, a secure deployment webhook is dispatched to Render, triggering a rolling zero-downtime container update.

CHAPTER 14

Verification Strategy, Quality Assurance & Benchmarks

14.1 76-Suite Automated Pytest Verification Matrix

Quality assurance in security tooling is paramount; a scanner that fails or produces erroneous results undermines security operations. ShadowTrace is backed by a comprehensive automated test suite consisting of **76 automated Pytest suites** covering 100% of critical security and parsing modules:

Test Subsystem	Test Count	Tested Subsystems & Functionality	Pass Rate & Status
SSRF & Network Boundary	14 Tests	Loopback (127.0.0.1, ::1), RFC 1918 subnets, AWS metadata (169.254.169.254), DNS rebinding TOCTOU simulation.	14 / 14 PASS (100%)
JavaScript Lexical Parser	12 Tests	Fetch API, Axios methods, template literal interpolation, minified bundle token extraction.	12 / 12 PASS (100%)
Source Map Reconstructor	8 Tests	SourceMappingURL parsing, v3 JSON schema validation, source file reconstruction, multi-chunk bundle mapping.	8 / 8 PASS (100%)
Parameter Templating	10 Tests	UUIDv4, sequential integer IDs, MD5/SHA hex strings, base64 tokens, slug normalization, deduplication.	10 / 10 PASS (100%)
Baseline Reconciler	10 Tests	OpenAPI 3.0/3.1 parser, Swagger 2.0 parser, Shadow API classification, Zombie API classification, Orphan detection.	10 / 10 PASS (100%)
Soft-404 Mitigation	8 Tests	Multi-sample random path probing, Shannon entropy comparison, DOM similarity, SPA fallback discrimination.	8 / 8 PASS (100%)
Risk Scoring Engine	8 Tests	Monotonic ordering proof, mathematical bound assertions [0, 100], exposure multiplier weighting.	8 / 8 PASS (100%)
FastAPI REST Controllers	6 Tests	Scan lifecycle, SSE event streaming, findings query filters, report export endpoints, authentication barriers.	6 / 6 PASS (100%)

14.2 Frontend Vitest Component Testing Strategy

The frontend user interface is validated through **15 automated Vitest specifications** utilizing `@testing-library/vue` and `jsdom`. These tests verify:

- **Component Rendering:** Verifies that all components (`ScanManager`, `ScanStreamMonitor`, `EndpointInventoryTable`) mount cleanly and render initial states.
- **SSE Stream State Machine:** Simulates incoming Server-Sent Events (`phase_change`, `endpoint_discovered`, `scan_completed`) and asserts that the UI state updates reactively.
- **Theme Switching Engine:** Validates that toggling the theme switch modifies HTML class attributes and correctly persists the selected mode in browser `localStorage`.
- **Form Validation & Input Sanitization:** Ensures that invalid target URLs or negative crawl depths are blocked client-side with descriptive error tooltips.

14.3 SSRF Attack Simulation & Concurrency Load Benchmarks

To evaluate performance and safety under adversarial conditions, ShadowTrace was subjected to rigorous stress and penetration testing:

- **SSRF Injection Test:** 500 adversarial URLs (including octal IP encodings like `0177.0.0.1`, hex encodings, DNS rebinding domains, and IPv6 loopback variants) were submitted to the scanner. **Result:** 100% of malicious probes were intercepted and rejected by pre-flight validation. Zero outbound requests reached private subnets.
- **Scan Throughput Benchmark:** Auditing a complex Single-Page Application with 32 JavaScript bundles, 14 source maps, and 85 unique API endpoints:
  - Total Discovery & Verification Elapsed Time: **48.2 seconds**
  - Peak Memory Consumption: **142 MB RAM**
  - Average CPU Utilization: **18.4% on 2 vCPUs**
  - Route Deduplication Ratio: **94.2% reduction** (collapsed 1,460 raw URLs into 85 canonical routes)

CHAPTER 15

Engineering Reflections, Future Roadmap & References

15.1 Technical Challenges Overcome & Internship Reflections

Engineering ShadowTrace during the HackHalt Cybersecurity Research Internship provided profound practical exposure to the intersection of offensive security research, distributed systems architecture, and robust full-stack software development. Several formidable engineering challenges were successfully solved:

- **Solving Asynchronous SQLite Concurrency:** In high-throughput async pipelines, standard SQLite configurations frequently throw `sqlite3.OperationalError: database is locked`. By implementing Write-Ahead Logging (WAL) mode, tuning connection pool timeouts, and batching write operations through asynchronous queues, database locking was completely eliminated.
- **Defeating Single-Page App Soft-404 Ambiguity:** Distinguishing between a genuine API endpoint returning JSON and an SPA catch-all router serving HTML required extensive statistical calibration. Developing the multi-sample Shannon entropy and body variance engine eliminated false positives without degrading scan speed.
- **Reconstructing Production Source Maps:** Decoding complex Webpack and Vite source map structures to extract raw TypeScript files required building a custom recursive JSON parser capable of handling corrupted or incomplete map files safely.

15.2 Future Engineering Roadmap

While ShadowTrace is currently a production-ready platform deployed live on Render, several exciting architectural enhancements are planned for future versions:

1. **Distributed Worker Architecture (Celery / Redis):** Decoupling the scanner engine from the FastAPI web server into horizontally scalable Celery worker nodes managed via Redis message queues, enabling enterprise clusters to audit thousands of domains simultaneously.
2. **AI-Powered Parameter Synthesis:** Integrating local Large Language Models (LLMs) to automatically synthesize semantically valid request parameters for newly discovered shadow endpoints, enabling deeper automated vulnerability exploration.
3. **eBPF Kernel Probing for Cloud-Native Environments:** Developing an extended Berkeley Packet Filter (eBPF) sidecar agent capable of passively monitoring internal Kubernetes pod-to-pod network traffic to discover internal service-to-service Shadow APIs at the Linux kernel level.

15.3 Formal Academic & Industry Standards References

1. OWASP Foundation. *OWASP API Security Top 10 2023*. OWASP API9:2023 Improper Inventory Management.
2. PCI Security Standards Council. *Payment Card Industry Data Security Standard (PCI DSS) Requirements and Testing Procedures Version 4.0*, Requirement 6.3.2 (Software and API Inventory), 2022.

3. Fielding, R., Nottingham, M., & Reschke, J. *HTTP Semantics (RFC 9110)*. Internet Engineering Task Force (IETF), June 2022.
4. National Institute of Standards and Technology (NIST). *Technical Guide to Information Security Testing and Assessment (Special Publication 800-115)*, 2008.
5. Barth, A. *HTTP State Management Mechanism (RFC 6265)*. Internet Engineering Task Force (IETF), April 2011.
6. Rescorla, E. *The Transport Layer Security (TLS) Protocol Version 1.3 (RFC 8446)*. IETF, August 2018.
7. Common Weakness Enumeration (CWE). *CWE-306: Missing Authentication for Critical Function*, MITRE Corporation.
8. Common Weakness Enumeration (CWE). *CWE-639: Authorization Bypass Through User-Controlled Key (IDOR/BOLA)*.
9. Common Weakness Enumeration (CWE). *CWE-918: Server-Side Request Forgery (SSRF)*, MITRE Corporation.
10. OpenAPI Initiative. *OpenAPI Specification v3.1.0*. Linux Foundation Collaborative Projects, 2021.

Document Completion Attestation: This comprehensive engineering report documents the architecture, implementation, verification, and deployment of ShadowTrace, designed and engineered by Amrrish during the HackHalt Cybersecurity Research Internship, November 2026.